CHAPTER 3: NETWORK SECURITY IN CLOUD ENVIRONMENTS

3.1 Cloud Network Architecture and Security : Cloud network architecture defines how cloud resources, users, applications, and data are interconnected and how traffic flows between them. It encompasses connectivity between on-premises infrastructure and cloud, internal cloud networking, and the placement of security controls such as firewalls, security groups, NAT gateways, and VPNs.
Unlike traditional data centres, where the network perimeter is physical, cloud networks are software-defined, meaning all components, routers, switches, and firewalls are virtualised and managed through APIs and configuration code.

3.1.1 Cloud Service Models and Security Responsibilities

Service Model	Description	Customer Controls	Security Responsibility
IaaS	Virtual machines, storage, and networking like renting a data centre.	OS, apps, data, middleware, runtime	The customer is responsible for everything above the hypervisor
PaaS	Ready-made platform focus on writing code, not managing servers.	Applications and data only	Provider handles OS and runtime; customer handles app security
SaaS	Complete software delivered over the internet (Gmail, Salesforce).	User access and data settings only	Provider handles almost everything; the customer manages access
FaaS / Serverless	Functions triggered by events; no server management at all.	Function code and IAM only	Provider manages all infrastructure automatically

Example IaaS Security Responsibility: A company uses AWS EC2 (IaaS) to host a web server. AWS secures the physical data centres and the hypervisor. The company must patch the Ubuntu OS, configure security groups, install a firewall, and harden the web server. If they forget to patch a vulnerability, they are liable AWS is not.

3.1.2 Cloud Deployment Models

Model	Who Owns Infrastructure?	Best For	Security Trade-off
Public Cloud	Third-party provider (AWS, Azure, GCP)	Startups, variable workloads, global reach	Multi-tenancy risk: rely on the provider's shared controls
Private Cloud	Single organisation (on-prem or hosted)	Regulated industries, sensitive data, compliance	Full control, higher capital cost, and management burden
Hybrid Cloud	Both public and private are linked together	Banks, healthcare sensitive data on-prem, apps in cloud	Complexity of securing the connection between environments
Multi-Cloud	Multiple public providers simultaneously	Avoid vendor lock-in, geo-specific services	Inconsistent security controls across providers; complex governance
Community Cloud	Shared by organisations with common needs	Government agencies, healthcare consortia	Shared but limited group; better than public for compliance

Case Study 3.1A — Capital One 2019 Cloud Misconfiguration Breach

Background: Capital One stored sensitive customer data on AWS S3, using EC2 instances with IAM roles to access it. A former AWS employee exploited a Server-Side Request Forgery (SSRF) vulnerability in Capital One's Web Application Firewall.
Attack Chain: The attacker sent a crafted HTTP request that the misconfigured WAF forwarded to the AWS Instance Metadata Service (IMDS) at 169.254.169.254. The IMDS returned temporary IAM credentials for the EC2 instance's role.
Impact: Using those credentials, the attacker listed and downloaded S3 buckets containing 106 million customer records, including names, addresses, credit scores, and some Social Security numbers. The OCC fined Capital One $80 million.
Root Causes:
1) WAF misconfiguration allowed SSRF.
2) The EC2 IAM role had excessive S3 permissions (ListAllBuckets and GetObject on all buckets).
3) IMDSv1 (no session requirement) was in use.
Lessons Learned: Enable IMDSv2 (session-oriented metadata) to block SSRF attacks. Apply least-privilege IAM EC2 roles should only access specific S3 buckets they need. Use VPC endpoint policies. Regularly audit IAM permissions.

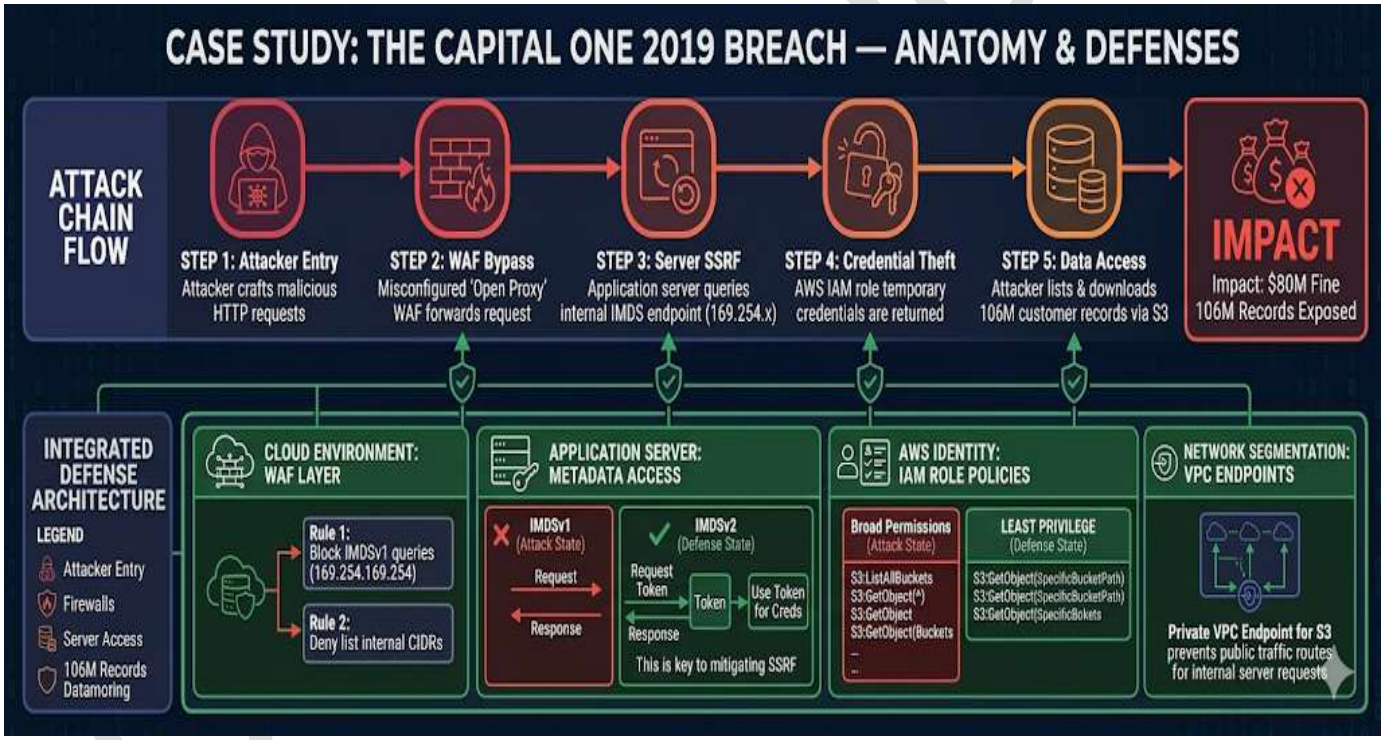

Figure: Case Study 3.1A — Capital One 2019 SSRF Attack Chain and Remediation

The Anatomy of the Attack

The breach wasn't just one mistake; it was a sequence of events where each step allowed the attacker to go deeper into the infrastructure.

The Entry Point (WAF Bypass): The attacker targeted a Web Application Firewall (WAF) that was misconfigured. Instead of blocking malicious traffic, it was acting as an open proxy, forwarding the attacker's requests directly to the internal application server.

The SSRF Trick: The attacker sent a request that forced the server to talk to itself. Specifically, they targeted the Instance Metadata Service (IMDS) at the internal IP 169.254.169.254. This is a "magic" IP in AWS that holds information about the server's configuration.

Credential Theft: By querying the IMDS, the attacker was able to trick the server into handing over its IAM Role credentials (temporary security keys).
Data Exfiltration: With those keys in hand, the attacker could "impersonate" the server. Since the server had overly broad permissions, the attacker was able to list and download data from S3 buckets containing 106 million customer records.

How it Could Have Been Stopped
The green box at the bottom highlights the "Defense in Depth" strategies that were missing:
IMDSv2: Unlike the original IMDS (v1) used here, IMDSv2 requires a session token. An SSRF attack generally cannot easily retrieve and use this token, which would have killed the attack at Step 3.
Least Privilege IAM: The server's "identity" had permission to list and read *all* buckets. If it only had access to the specific files it needed to function, the attacker would have hit a wall.
WAF SSRF Rules: A properly configured WAF would have recognized the request to the 169.254.x.x address as malicious and blocked it immediately.

The "Impact" Reality Check
The image mentions an $80M fine, but the reputational damage was arguably much higher. It remains the go-to case study for why cloud security relies on Identity (IAM) just as much as it does on Firewalls.

Chandan lohar

3.1.3 Key VPC Network Components

A Virtual Private Cloud (VPC) is a logically isolated virtual network inside a public cloud. You control IP address ranges, subnets, route tables, and gateways effectively building a private data centre inside the cloud provider's infrastructure.

Component	Function	Security Relevance
Subnets	Divide the VPC address space into smaller ranges. Public subnets have internet routes; private subnets do not.	Isolates resources — databases and back-end services placed in private subnets are unreachable from the internet.
Internet Gateway (IGW)	Enables two-way communication between VPC resources and the internet.	Only attach to VPCs that require public-facing services. Without an IGW, no internet access at all.
NAT Gateway	Allows private subnet instances to initiate outbound connections without accepting inbound requests.	Enables patches and updates for private instances while keeping them unreachable from the internet.
Security Groups	Stateful instance-level virtual firewall. Return traffic is automatically allowed.	Default deny-all inbound. Define exactly which ports/protocols each instance exposes and to whom.
Network ACLs	Stateless subnet-level filter. Both inbound and outbound rules must be explicitly defined.	Additional defence layer; useful for blocking specific IP ranges across an entire subnet.
VPN Gateway	Cloud-side endpoint for IPsec VPN tunnels to on-premises networks.	Encrypted path from corporate data centre to cloud VPC without traversing the public internet.
Direct Connect / ExpressRoute	Dedicated private fibre link from the customer's data centre to the cloud.	Higher throughput and lower latency than VPN; no public internet exposure at all.
VPC Peering	Direct logical link between two VPCs for private routing.	Non-transitive: A<->B and B<->C does NOT give A<->C. Use Transit Gateway for hub-and-spoke.
Transit Gateway	Central hub connecting many VPCs and on-premises networks.	Simplifies and centralises network management; applies shared inspection and firewall policies.
VPC Flow Logs	Capture metadata about all traffic to/from network interfaces.	Essential for security investigations, anomaly detection, and compliance audit trails.

Chandan Lohar

Example — NAT Gateway Use Case:

An auto-scaling group of application servers sits in private subnets (10.0.2.0/24). They need to download OS patches and pull Docker images from public registries. A NAT Gateway is placed in the public subnet. The private instances route internet-bound traffic to the NAT Gateway, which translates the source IP to its own Elastic IP. Traffic from the internet cannot initiate connections to these instances — only responses to requests they initiated are allowed back through.

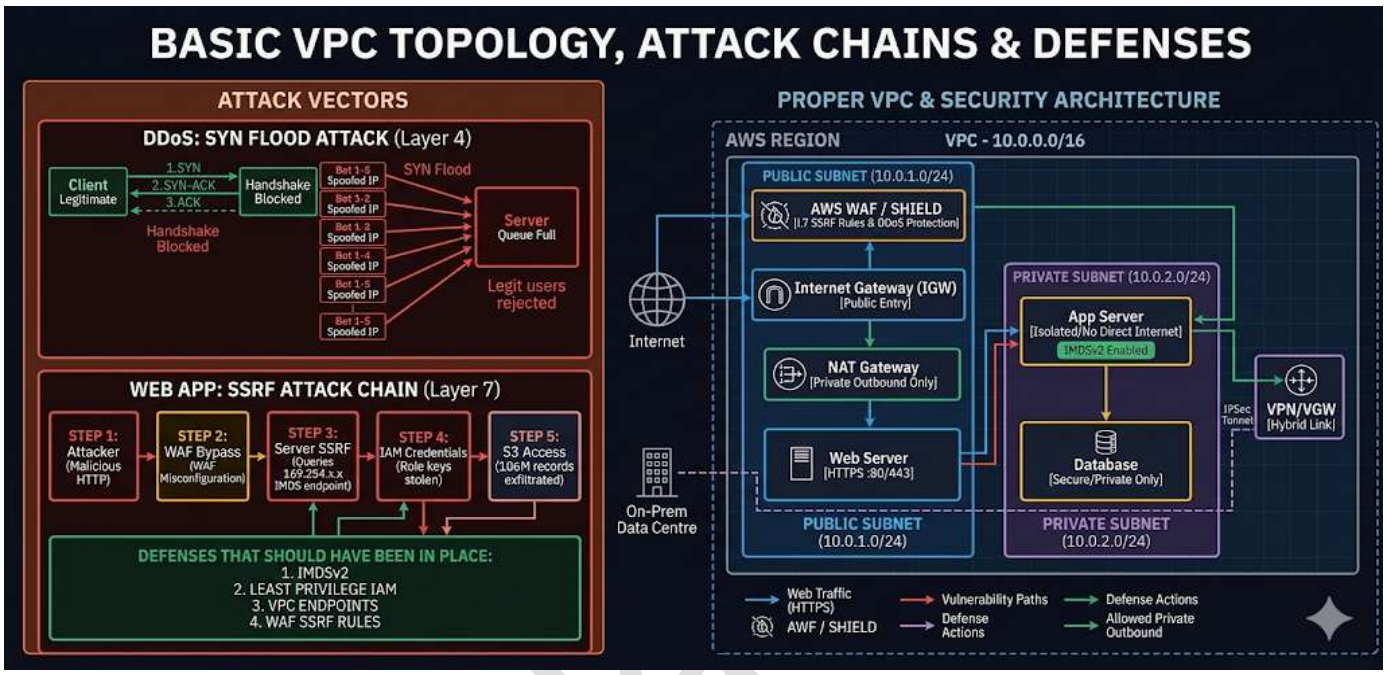

Figure: 3.1 — Basic VPC Topology: Public Subnet (IGW, Web), Private Subnets (App, DB, VPN)

Core Components of VPC Topology

1. The Subnets

A VPC is typically divided into two types of subnets to manage security and traffic flow:

Public Subnet: Resources in this subnet are accessible from the internet. This is where you place Web Servers, Load Balancers, and NAT Gateways. It has a route in its route table to an Internet Gateway.

Private Subnet: Resources here have no direct route to the internet. This is the "vault" for Databases, Application Servers, and Internal Logic. These resources can only talk to the internet *outbound* (for updates) via a NAT Gateway.

2. The Gateways (Connectivity)

Internet Gateway (IGW): The bridge between your VPC and the public internet. It allows resources with public IPs to communicate with the outside world.

NAT Gateway: Located in the public subnet, it allows private resources to reach the internet without exposing their private IP addresses. It’s a "one-way" street for security.

Virtual Private Gateway (VPG/VGW): Used to establish a secure VPN or Direct Connect link between your On-Premises Data Center and your cloud VPC.

3. Security Layers

VPC topology relies on a "Defense in Depth" strategy:

Network ACLs (NACLs): A stateless firewall at the subnet level. It controls traffic entering or leaving the entire subnet.

Security Groups: A stateful firewall at the instance level (the server itself). It acts as a virtual firewall for your EC2 instances to control inbound and outbound traffic.

Typical Traffic Flow

Incoming: A user hits the Internet Gateway $\rightarrow$ directed to a Web Server in the Public Subnet.
Internal: The Web Server processes the request and communicates with the App Server in the Private Subnet.
Data: The App Server queries the Database (deepest part of the Private Subnet).
Outgoing Updates: If the Database needs a patch, it sends a request through the NAT Gateway $\rightarrow$ out the Internet Gateway.
Why use this Topology?
Isolation: Hackers cannot directly "ping" your database because it has no public route.
Control: You define the IP address range (CIDR blocks), create subnets, and configure route tables.
Hybrid Cloud: You can seamlessly connect your physical office to the cloud, making it act like one large internal network.

Chandan lohar

3.1.4 Shared Responsibility Model

Cloud security responsibility is shared between the provider and the customer. The split depends on the service model:

3.1 Shared Responsibility Model

Responsibility Area	Cloud Provider		Customer
Physical Infrastructure	✓ Provider		—
Network Infrastructure	✓ Provider		—
Operating System (PaaS/SaaS)	✓ Provider		—
Operating System (IaaS)	—		✓ Customer
Applications & Runtime	—		✓ Customer
Data & Access Control	—		✓ Customer
Regulatory Compliance	✓ Provider (Standards)	SHARED: Compliance *of* the Cloud (P) vs Compliance *in* the Cloud (C)	✓ Customer (Policy Enforcement)
Data Classification & Governance	—	*C: Global Industry Standards (SOC2, ISO)* *S: (shared) Application-level certifications*	✓ Customer *C: Data Identification & Access Policies*
Client-side Data Encryption	—	P: Data Industry Standards Policies)	✓ Customer *C: Data Encryption before upload*
Server-side Data Encryption	✓ Provider (Encryption at Rest with Service-Managed Keys)	✓ Provider (Encryption) *P: Default and configurable storage encryption*	✓ Customer (Key Management) *C: Managing Key Rotation Policies*
Host OS Firewall Configuration	—	—	✓ Customer (Configuration) *C: Securing host (e.g., configuring iptables or firewalld) in IaaS*
Customer Web App Firewall	—	—	✓ Customer *C: WAF rule tuning and maintenance*

Figure 3.1 — Shared Responsibility Model: Provider vs Customer across Service Models

Detailed Breakdown by Responsibility Area

1. Physical Infrastructure
Who is responsible? Cloud Provider
Explanation: This refers to the actual tangible buildings (data centers), the land they sit on, the security guards, surveillance cameras, and physical locks that protect the servers. The customer has zero control over this, so the provider handles it entirely.
2. Network Infrastructure
Who is responsible? Cloud Provider
Explanation: This covers the physical routers, switches, and fiber optic cabling that connect the servers within the data center. It also includes the underlying network software that allows the provider to carve out private, virtual networks for customers.
3. Operating System (PaaS/SaaS)
Who is responsible? Cloud Provider
Explanation: When you use a structured platform or application (like Google Workspace, Salesforce, or a managed database service), the cloud provider patches, updates, and manages the operating system. You are just a user of the service; you don't choose or maintain the OS itself.
4. Operating System (IaaS)
Who is responsible? Customer
Explanation: When you lease virtual machines (IaaS), the cloud provider gives you the 'blank' server and lets you choose your preferred OS (e.g., Linux or Windows). Because you chose it, you must configure it, apply security patches, and update it.
5. Applications & Runtime
Who is responsible? Customer
Explanation: The cloud provider just provides the environment (the runtime), but they have no insight into the code you're writing or the software you are installing. If your web application has a vulnerability that allows hackers to steal data, that is a customer responsibility.

Chandan

6. Data & Access Control

Who is responsible? Customer

Explanation: This is the most critical area. The provider gives you a 'bucket' to store data, but you must decide:

1.What data to put inside.

2.Who has permission to read, write, or delete it (access controls).

3.If the data should be encrypted.

4.If you choose not to lock the door to your bucket, it is the customer's fault if data is exposed.

Key Insight:

CRITICAL POINT: 'Shared responsibility' does NOT mean shared blame when something goes wrong. If a customer leaves an S3 bucket publicly accessible, that is entirely the customer's fault the provider's responsibility ended at making the access control feature available. Customers must fully understand what they are responsible for in each service model.

Chandan lohar

3.1.5 Defence-in-Depth

Defence-in-depth means applying multiple overlapping security controls so that no single failure exposes the system. It applies the principle that attackers must defeat several independent layers to succeed.

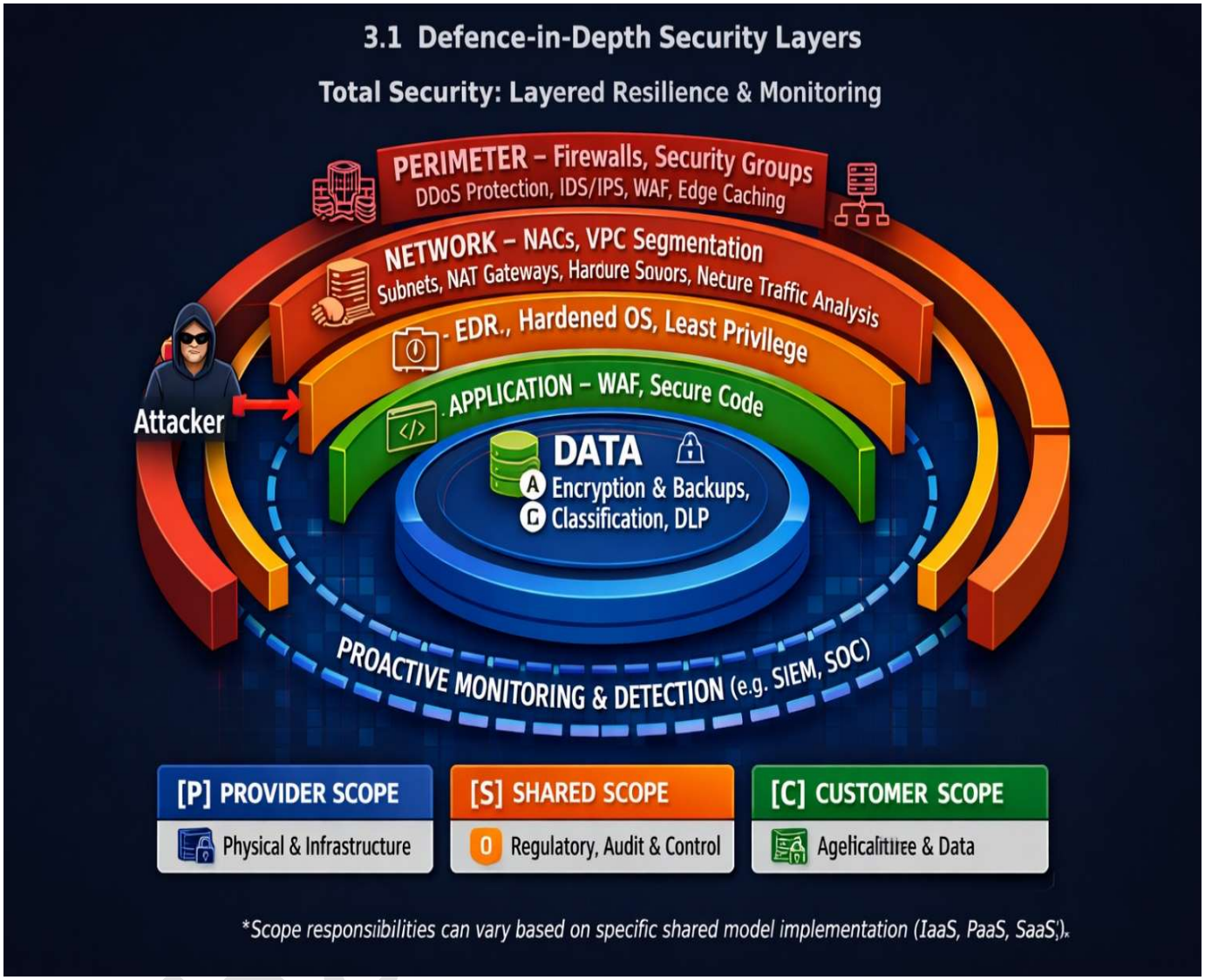

Figure 3.1 — Defence-in-Depth: Concentric Security Layers from Perimeter to Data

The Shared Responsibility Model: Who Does What?
The top header establishes the parties involved, color-coded for clarity.
1. Cloud Provider (Blue Box): Responsibilities in blue are handled exclusively by the provider (e.g., Google Cloud, AWS, Azure, Microsoft). These are tasks relating to the physical and underlying virtual infrastructure.
2. Customer (Green Box): Responsibilities in green are handled exclusively by the customer. These relate to configurations, data, and access controls within the virtual environment.

The Concept of Defense-in-Depth (Layered Security)

The nested elliptical bands surrounding the central DATA core represent independent security boundaries or "layers." Each layer has a distinct purpose and is designed to detect, slow down, or block an attacker. If an attacker breaches one layer, the next layer acts as a redundant backup.

Detailed Breakdown by Layer (Outermost to Innermost)

We will explore each security layer shown in the diagram, identifying its function and assigning responsibility based on the diagram's color coding.

Layer (From Outside In)	Key Responsibilities & Tools	Responsibility Party
0. The Attacker	*External threat actor trying to breach the system.*	*N/A (Represents the threat).*
1. PERIMETER	First line of defense separating the cloud from the internet.	Customer
	• Firewalls (e.g., Web Application Firewalls - WAF)	
	• Security Groups (Nets of traffic rules)	
2. NETWORK	Internal traffic segmentation within your private cloud.	Customer
	• NACLs (Network Access Control Lists)	
	• VPC Segmentation (Virtual Private Clouds)	
3. HOST	Protecting the actual operating system (servers) being used.	Shared
	• Patching (Installing security updates)	• *Customer handles IaaS (Guest OS).*
	• Host-based Firewalls	• *Provider handles PaaS/SaaS (Abstract OS).*
4. APPLICATION	Securing the software code and runtime environment.	Customer
	• WAF (Applying rules specific to apps)	
	• Secure Code (Writing code without bugs/exploits)	
5. DATA (Core)	The ultimate asset being protected.	Customer
	• Encryption (Making data unreadable to those without the key)	
	• Backups (Ensuring data availability after a loss)	

Layer	Controls	Example Tools
Perimeter	Firewalls, WAFs, and Security Groups block external threats	AWS WAF, Azure Firewall, Cloudflare
Network	NACLs, VPC segmentation, and routing controls limit internal movement	VPC subnets, Transit Gateway, route tables
Host	OS patching, EDR agents, and host-based firewalls on each instance	CrowdStrike, AWS Systems Manager Patch Manager
Application	Input validation, SAST/DAST scanning, secure coding standards	OWASP, Snyk, AWS CodeGuru
Data	Encryption at rest and in transit, key management, DLP, backups	AWS KMS, Azure Key Vault, Macie

3.2 Virtual Private Cloud (VPC) and Network Segmentation

Network segmentation divides a network into smaller, isolated sections called segments or zones. Within a cloud VPC, segmentation is achieved through subnets, security groups, NACLs, and routing policies. Each segment has its own security policy tailored to the sensitivity of the resources it contains.

3.2.1 Why Network Segmentation Matters

Benefit	Explanation	Real-World Example
Limits Blast Radius	If attackers breach one segment, controls prevent them from moving laterally to others.	A compromised web server cannot directly reach the database if SGs deny that traffic.
Least Privilege Networking	Resources can only communicate with what they need — nothing else.	App servers can reach the DB on port 5432; they cannot reach the payment vaults.
Regulatory Compliance	PCI DSS, HIPAA, and GDPR require cardholder and health data to be isolated.	PCI DSS Requirement 1: Install network controls between cardholder data and other zones.
Improved Performance	Separating traffic types prevents noisy workloads from impacting critical systems.	Video processing jobs isolated from the OLTP transaction database.
Simplified Auditing	Smaller, clearly defined segments are easier to monitor and audit.	Flow logs per subnet for the PCI zone are kept for 12 months for auditors.

3.2.2 Segmentation Mechanisms

Security Groups vs Network ACLs

Feature	Security Groups (SGs)	Network ACLs (NACLs)
Level	Instance (ENI) level	Subnet level
State	Stateful — return traffic auto-allowed	Stateless — must explicitly allow both directions
Default Behaviour	Deny all inbound; allow all outbound	Allow all inbound and outbound
Rule Evaluation	All rules evaluated; most permissive wins	Rules evaluated in order; first match wins
Best Used For	Fine-grained per-instance control	Broad subnet-wide blocks (e.g., block a country's IP range)
Can Block Specific IPs?	Not directly (allow-only rules)	Yes — explicit deny rules possible

Example — SG and NACL Working Together:
An e-commerce web server is in a public subnet. The Security Group allows inbound TCP 443 (HTTPS) from 0.0.0.0/0 and TCP 22 (SSH) only from the company's office IP (203.0.113.5/32). The NACL for the same subnet has an explicit DENY for traffic from a known malicious IP block (198.51.100.0/24). Both controls apply: the NACL blocks traffic at the subnet boundary first; the SG provides additional granular control at the instance level.

3.2.3 Three-Tier Architecture — Worked Example

A three-tier architecture is the most widely deployed cloud application pattern. It physically and logically separates presentation, logic, and data layers into different subnets with controlled access between each tier.

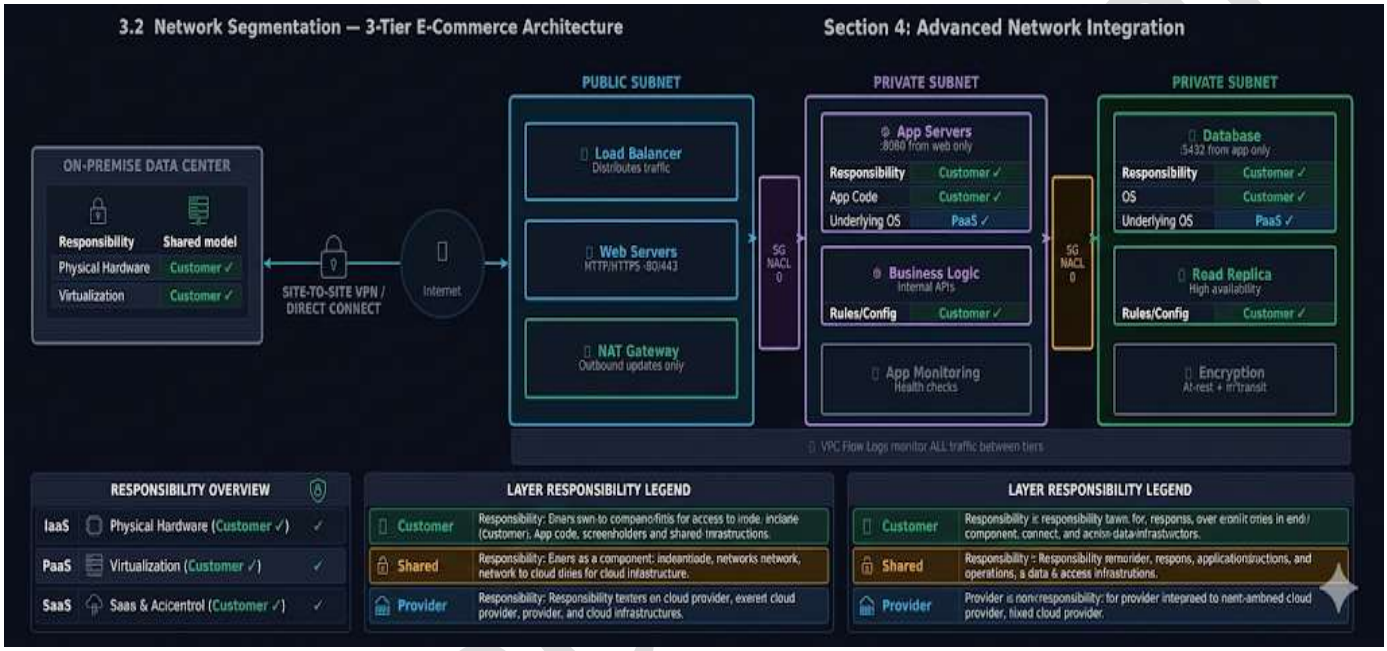

Figure: 3.2 — 3-Tier Segmented Architecture: Web (Public) > App (Private) > DB (Private)

Tier 1 — Presentation (Public Subnet: 10.0.1.0/24)
Contains: Load balancer, web servers, CDN origin.
Security Group allows: Inbound 443 (HTTPS) from the internet; inbound 80 redirected to 443.
Security Group denies: All direct access to database or app ports from the internet.
Route table: Default route to Internet Gateway.

Tier 2 — Application (Private Subnet: 10.0.2.0/24)
Contains: App servers, microservices, business logic containers.
Security Group allows: Inbound 8080 only from web tier SG reference (not from the internet).
Security Group denies: All direct internet access; outbound only via NAT Gateway.
Route table: Default route to NAT Gateway for outbound; no Internet Gateway.

Tier 3 — Data (Private Subnet: 10.0.3.0/24)
Contains: Primary database, read replicas, caching layers (Redis/ElastiCache).
Security Group allows: Inbound 5432 (PostgreSQL) ONLY from app tier SG reference.
Security Group denies: Absolutely no internet access inbound or outbound.
Encryption: Data encrypted at rest (AES-256) and in transit (TLS).

Case Study 3.2A — Netflix: VPC Segmentation and Chaos Engineering

Context: Netflix operates across three AWS regions simultaneously (us-east-1, us-west-2, eu-west-1) and processes billions of streaming requests daily. Each region contains isolated VPCs per environment (production, staging, canary).
Segmentation Design: Netflix uses per-service VPCs rather than one large VPC. Each microservice (Recommendation Engine, Playback API, Content Ingestion) runs in its own VPC with strict peering controls. Communication between services uses private API endpoints, not public internet routes.
Chaos Engineering: Netflix runs Chaos Monkey — a tool that randomly terminates production instances to ensure their architecture survives failures. This validates that segmentation is correct (failed instances in one segment do not cascade to others) and that auto-scaling works as designed.
Zero Trust Networking: All internal service-to-service traffic is authenticated using mutual TLS (mTLS) even within VPCs. Just being inside the network is not sufficient — every service must prove its identity on every request.
Result: Netflix achieves 99.99% availability. Their Chaos Engineering discipline has become an industry standard for validating resilient, properly segmented architectures.

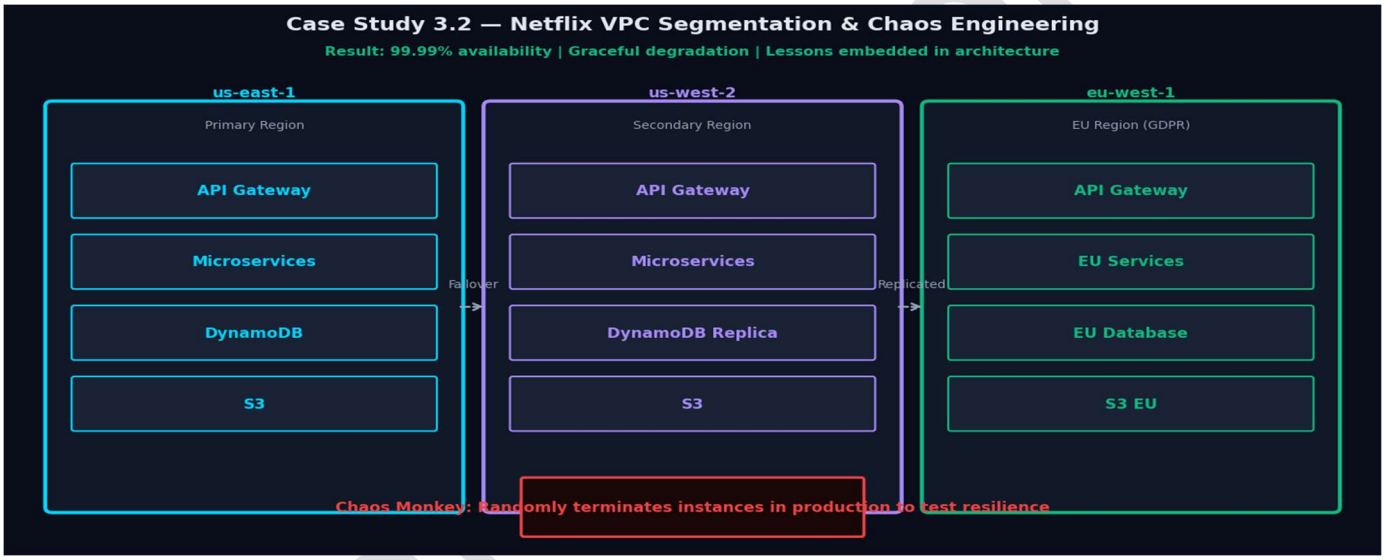

Figure: Case Study 3.2A — Netflix Multi-Region VPC Segmentation and Chaos Engineering

3.2.4 Micro-Segmentation

Micro-segmentation extends traditional network segmentation down to the individual workload or application level — even within the same subnet. It is a core component of Zero-Trust architectures.
Traditional segmentation: Subnets and security groups control inter-tier traffic.
Micro-segmentation: Service mesh (e.g., Istio, AWS App Mesh) controls service-to-service traffic within the same tier.
Benefit: A compromised container cannot communicate with any other service it was not explicitly allowed to reach — even if both are in the same subnet.

Case Study 3.2B — Google BeyondCorp: Zero Trust Network

Background: After the 2009 Aurora cyber-espionage attack on Google's corporate network, Google concluded that the traditional perimeter model ('trust the inside, block the outside') was fundamentally flawed.
Solution: Google rebuilt their internal network access model as BeyondCorp — now the reference implementation for Zero Trust. No internal network is trusted by default. Access is granted based on the combination of device health, user identity, and context — not based on network location.
How It Works: Every employee access request passes through an Access Proxy that checks: (1) Is the device corporate-managed and healthy? (2) Is the user authenticated with MFA? (3) Does their role allow this specific resource? All three must be true.
Impact: Google employees work securely from untrusted networks (cafes, home, airports) without needing a traditional VPN. The attack surface is reduced to individual resources rather than the entire network.
Industry Adoption: BeyondCorp principles are now implemented as commercial products: Google BeyondCorp Enterprise, Microsoft Azure AD Conditional Access, Zscaler Private Access, Cloudflare Access.

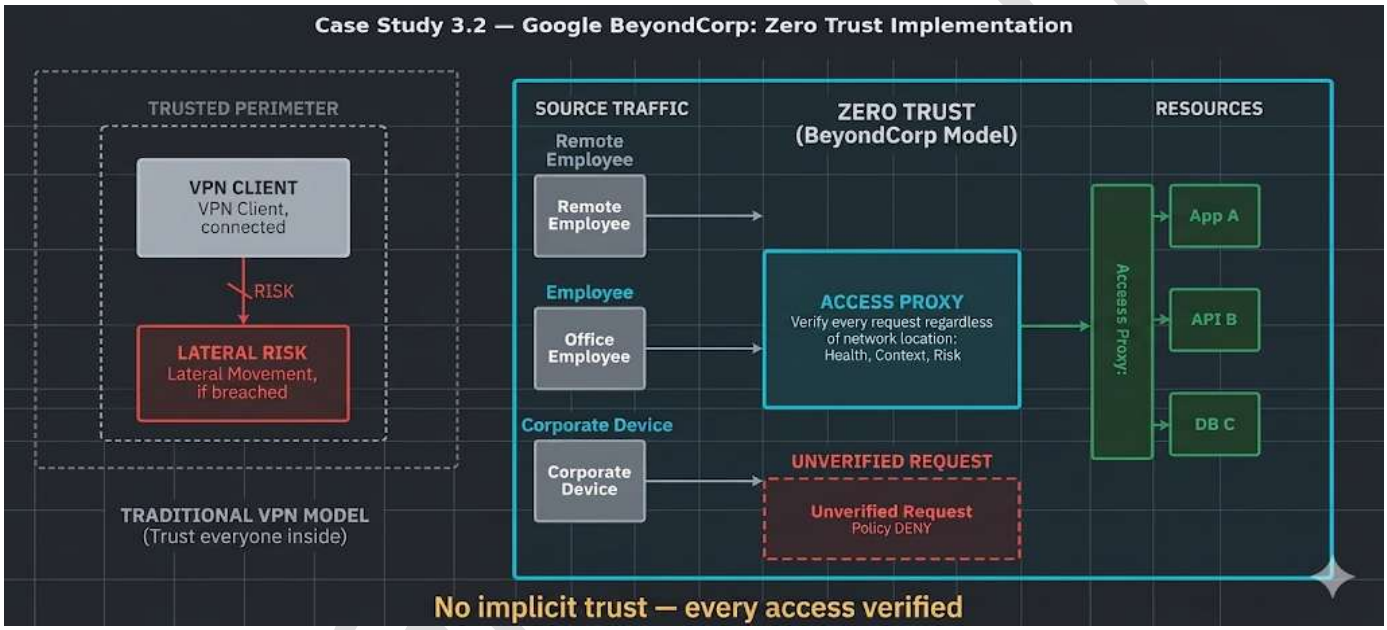

Figure: Case Study 3.2B — Google BeyondCorp Zero Trust Architecture

Design Tip:

BEST PRACTICE: When designing VPC segmentation, always draw your architecture diagram first and label every traffic flow with the protocol, port, and direction. For each flow, ask: 'Is this communication necessary?' If the answer is no, block it. If yes, restrict it to exactly the required port and source.3.3 Firewalls, Intrusion Detection Systems, and Intrusion Prevention Systems
Firewalls, IDS, and IPS form the three pillars of active network defence. Firewalls enforce access policies, IDS detects threats and raises alerts, and IPS detects and actively stops threats in real time. Used together, they provide overlapping layers of network protection.

3.3.1 Firewalls in Depth

A firewall inspects network traffic and applies a ruleset to decide whether each packet or connection should be allowed or blocked. Modern cloud firewalls operate at multiple levels of the OSI stack.

Firewall Type	OSI Layer	Capabilities	Cloud Equivalent
Packet-Filtering	L3/L4 only	Src/dst IP, port, protocol. Stateless — fast but limited.	AWS NACL, basic ACLs
Stateful Inspection	L3/L4 + state	Tracks connections; allows only packets part of established sessions.	AWS Security Groups, Azure NSGs
Proxy / App-Level	L7 (Application)	Terminates sessions; deep application-layer inspection; hides backend topology.	Squid Proxy, AWS NLB with TLS offload
Next-Gen Firewall (NGFW)	L2–L7	DPI, integrated IPS, app identification, TLS inspection, threat intelligence feeds.	AWS Network Firewall, Azure Firewall Premium, Palo Alto VM-Series
Web App Firewall (WAF)	L7 (HTTP/S only)	Blocks OWASP Top 10: SQLi, XSS, CSRF, path traversal, bot traffic.	AWS WAF, Azure WAF, Cloudflare WAF

Example — Security Group Rule for a Web Server:

Allow Inbound: TCP 443 (HTTPS) from 0.0.0.0/0 (any internet user) Allow Inbound: TCP 22 (SSH) from 203.0.113.10/32 (admin workstation only)
Deny Inbound: ALL other traffic (implicit default deny) Allow Outbound: TCP 8080 to App-Tier-SG (internal to app servers only) Allow
Outbound: TCP 443 to 0.0.0.0/0 (to reach external APIs) This SG allows public HTTPS access while restricting management access to a single trusted IP, and limits outbound traffic to only what is needed.

Chandan

3.3.2 Intrusion Detection Systems (IDS)

An IDS monitors network traffic and host activities for signs of malicious behaviour. It generates alerts for analysts to investigate, but does NOT block traffic — it is a passive detection system. Think of it as a security camera: it records and alerts, but does not lock the door.

Network IDS (NIDS) vs Host IDS (HIDS)

Feature	NIDS — Network-based	HIDS — Host-based
Placement	Tap/SPAN port on network segment; monitors all traffic passing through.	Runs as an agent on each individual host; monitors local files, logs, and syscalls.
What it sees	All inter-host traffic within a network segment.	System file changes, process creation, login events, registry changes.
Strengths	Broad visibility; a single sensor protects many hosts.	Detects attacks that don't appear as network traffic (insider threats, rootkits).
Weaknesses	Cannot see encrypted traffic content; blind to host-level events.	Must deploy and manage agents on every host; resource overhead.
Examples	Snort, Suricata, AWS GuardDuty (network), Zeek	OSSEC, Wazuh, Auditd, AWS GuardDuty (host findings)

Detection Approaches

Method	How It Works	Strengths / Weaknesses
Signature-Based	Compares traffic against a database of known attack signatures (like antivirus).	Excellent at detecting known threats; completely blind to zero-day attacks and novel malware.
Anomaly-Based	Builds a statistical baseline of normal behaviour; flags significant deviations.	Can detect unknown threats; high false-positive rate during establishment period.
Behaviour-Based	Tracks sequences of actions (processes, network calls) rather than individual packets.	More context-aware; better at detecting multi-stage attacks that evade signature detection.
Reputation-Based	Checks IPs, domains, and file hashes against threat intelligence feeds.	Fast and effective for known bad actors; useless for novel infrastructure.

3.3.3 Intrusion Prevention Systems (IPS)

An IPS is placed inline with network traffic — every packet passes through it. When the IPS detects a threat, it can drop the packet, reset the connection, block the source IP, or quarantine the host. It is an active participant in traffic flow, not a passive observer.

IPS Type	Deployment	Best For
Network IPS (NIPS)	Inline on network segments — all traffic must flow through it.	Protecting perimeter and between network segments; volumetric and protocol attacks.
Host IPS (HIPS)	Agent on each host; intercepts system calls before they execute.	Protecting individual critical servers; detecting process injection and privilege escalation.
Wireless IPS (WIPS)	Monitors RF spectrum for rogue access points and wireless attacks.	Corporate WiFi environments; detecting evil twin access points.
Cloud-Native IPS	Integrated into cloud firewall services (AWS Network Firewall, Azure Firewall Premium).	Cloud workloads; scales automatically; managed rule sets updated by provider.

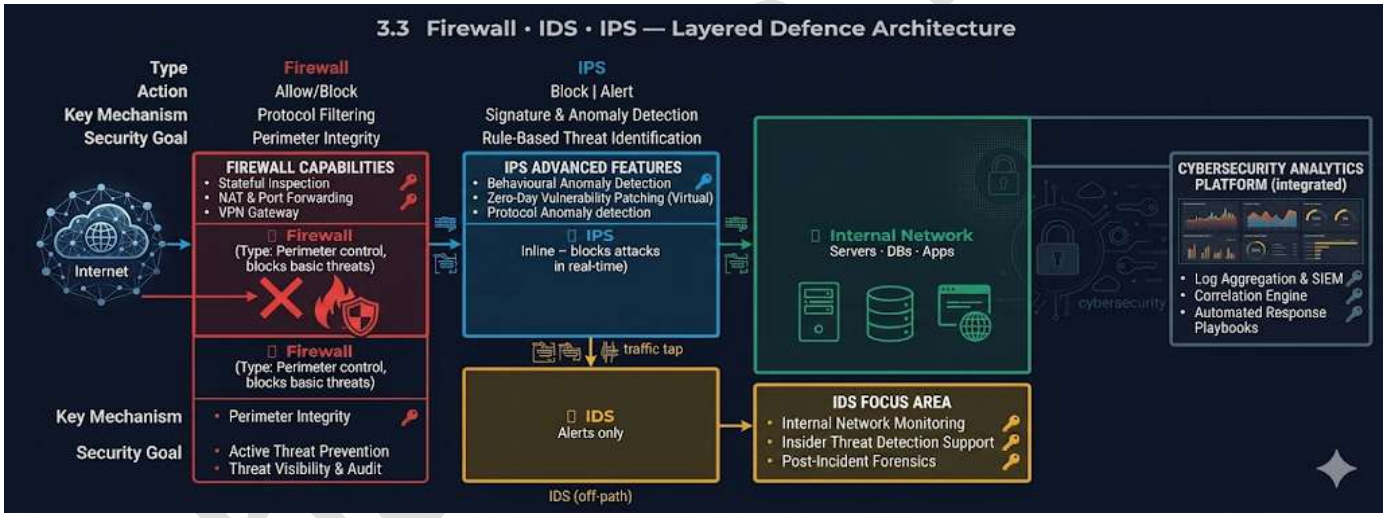

Figure: 3.3 — Firewall (perimeter) + IPS (inline) + IDS (passive tap) Layered Architecture

3.3.4 IDS/IPS in the Cloud — Practical Deployment

Cloud-Native Detection Services
AWS GuardDuty: Managed threat detection analysing CloudTrail, VPC Flow Logs, and DNS logs. Uses ML and threat intelligence to identify compromised instances, crypto-mining, data exfiltration.
Azure Sentinel: Cloud-native SIEM+SOAR that aggregates logs, applies analytics, and can trigger automated responses.
Google Chronicle: Google's security analytics platform; processes massive log volumes with sub-second search.

Case Study 3.3 — SolarWinds Supply Chain Attack: IDS Detection Challenge

Background: In 2020, attackers compromised SolarWinds' build pipeline and inserted malicious code into Orion software updates. The backdoor was installed on 18,000 organisations including US Government agencies.
Why IDS Failed to Detect: The malware was digitally signed (legitimate SolarWinds signature). It waited 12–14 days after installation before activating, staying below anomaly detection thresholds. It mimicked legitimate Orion traffic patterns using HTTP/S to blend in. It only communicated during business hours.
What Eventually Detected It: FireEye (a cybersecurity firm) detected the compromise of their own red team tools. They shared indicators of compromise (IoCs) with Microsoft and US CISA. GuardDuty and SIEM rules updated with new IoCs helped organisations detect the malware retroactively.
Lesson: Signature-based IDS with no signature cannot detect. Anomaly-based detection needs correct baseline. Supply chain attacks show that securing your own perimeter is insufficient if your software vendors are compromised. Zero Trust and privileged access controls would have limited the blast radius.
Industry Response: Executive Order 14028 (US) mandated Zero Trust adoption across federal agencies. Software Bill of Materials (SBOM) requirements introduced for software vendors supplying government.

Integration Note:
SYNERGY — How They Work Together: Firewall blocks known-bad traffic at the perimeter. IPS blocks sophisticated attacks inline (in real time). IDS monitors internal traffic, encrypted streams (via decryption), and host activities for stealth threats. SIEM correlates alerts from all three into a unified view. No single tool is sufficient on its own.

Chandan Ishar

3.4 Secure Communication Protocols — HTTPS, TLS, and VPNs

Securing data in transit is as important as securing data at rest. Even if an attacker cannot breach your servers, they may attempt to intercept traffic between users and servers (man-in-the-middle attacks) or eavesdrop on unencrypted communications. HTTPS, TLS, and VPNs each address different aspects of secure communication.

3.4.1 HTTPS — Hypertext Transfer Protocol Secure

HTTPS is HTTP layered on top of TLS. It provides three security properties: confidentiality (traffic is encrypted), integrity (traffic cannot be silently modified), and authentication (the server's identity is verified by a Certificate Authority). HTTPS is now the baseline requirement for all websites.

Why HTTPS Matters — Consequences of Plain HTTP
Credential theft: Login forms over HTTP send usernames and passwords in plaintext — any network observer can read them.
Session hijacking: Attackers can steal session cookies from HTTP traffic and impersonate authenticated users.
Content injection: Internet Service Providers and network middleboxes can inject ads, malware, or tracking scripts into HTTP responses.
Browser warnings: All major browsers now flag HTTP sites as 'Not Secure', damaging user trust and SEO rankings.

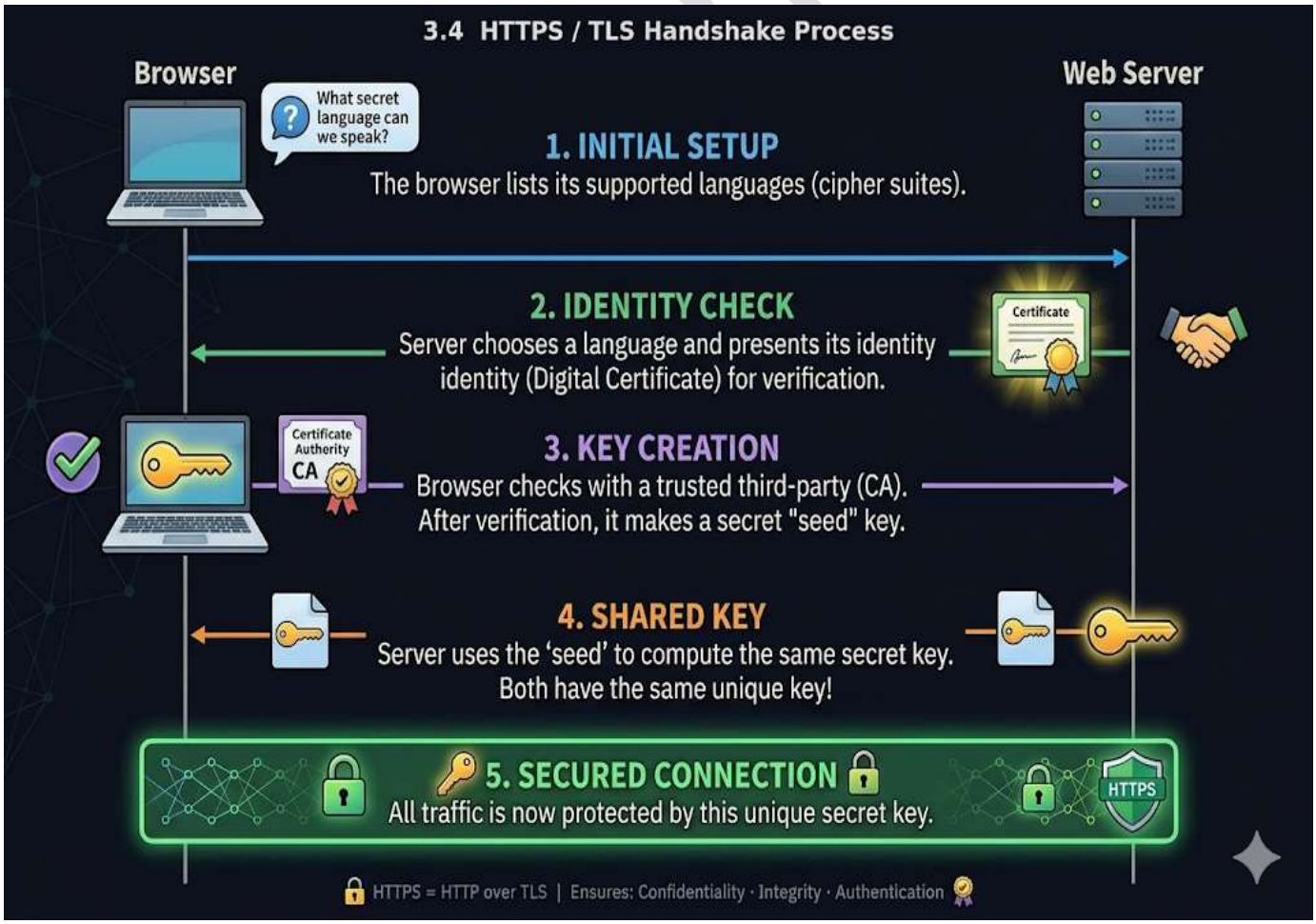

Figure: 3.4 — HTTPS/TLS Handshake: 5-Step Process from Client Hello to Encrypted Session

TLS Handshake — Step by Step

Step	Name	What Happens
1	Client Hello	Browser sends: TLS version supported, list of cypher suites (e.g. TLS_AES_256_GCM_SHA384), and a random nonce.
2	Server Hello	Server responds: selected cypher suite, its digital certificate (containing public key), and a random nonce.
3	Certificate Verification	The browser checks the certificate against the trusted Root CAs pre-installed in the OS/browser. Verifies: not expired, domain matches, not revoked (via CRL/OCSP).
4	Key Exchange	Client generates a pre-master secret, encrypts it with the server's public key (RSA) or performs ECDH key exchange. Both derive the same session key.
5	Secure Session	Both sides confirm with a 'Finished' message encrypted with the new session key. All subsequent traffic uses symmetric encryption (AES-256-GCM).

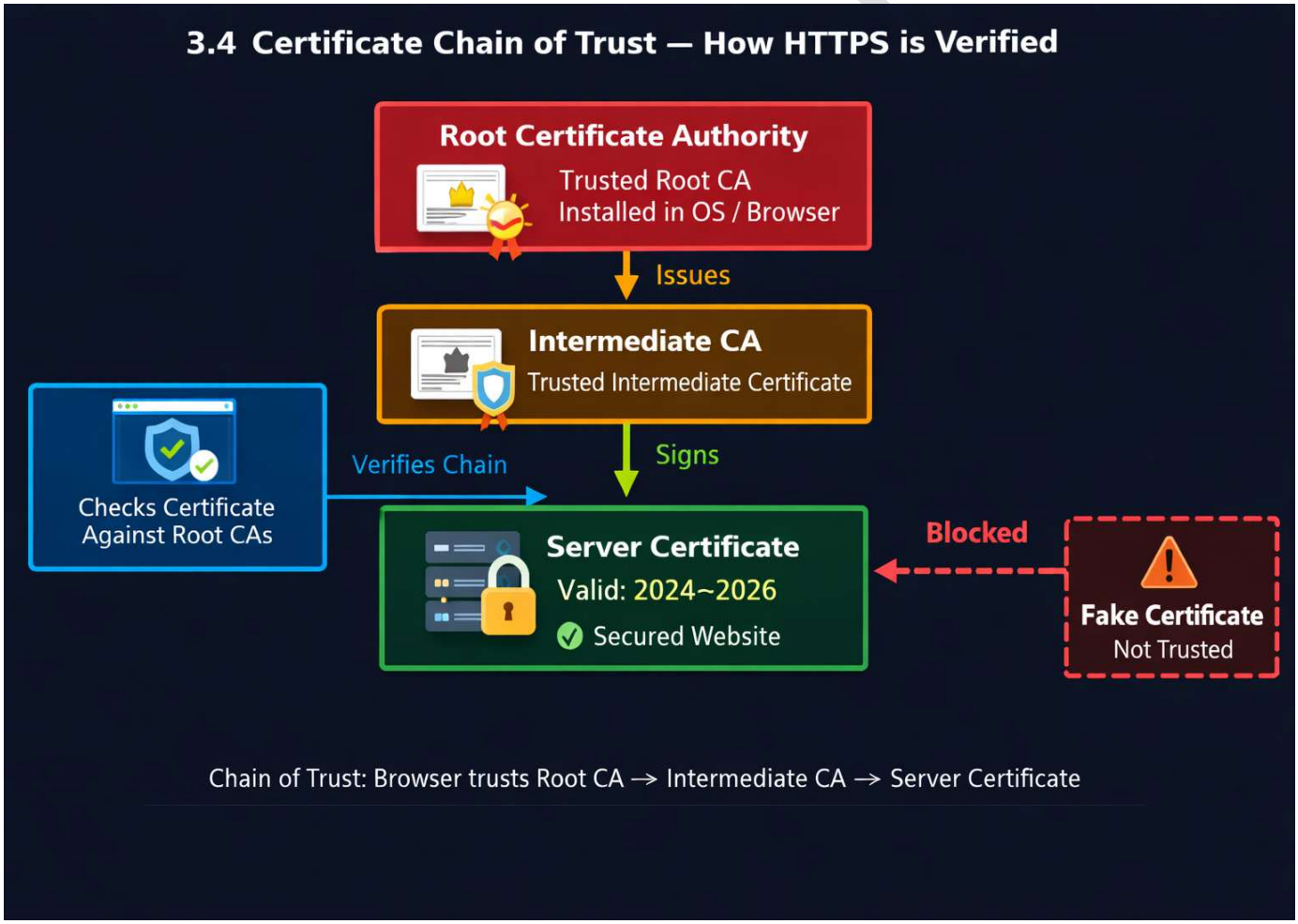

Figure: 3.4 — Certificate Chain of Trust: Root CA → Intermediate CA → Server Certificate

Example — Reading an SSL Certificate:
When you visit https://www.bank.com and click the padlock:
Subject: CN=www.bank.com, O=Bank Corp, C=US
Issuer: DigiCert SHA2 Extended Validation Server CA
Valid: 2024-01-15 to 2025-01-15
Public Key: RSA 2048-bit
SANs: www.bank.com, bank.com, mobile.bank.com
The browser verified this certificate was signed by DigiCert (a trusted CA), the domain matches the URL you visited, and the certificate has not expired or been revoked. The padlock confirms the TLS session is established.

3.4.2 TLS Versions and Cypher Suites

Version	Status	Security Notes
SSL 2.0 / 3.0	Fully deprecated	Broken — POODLE, DROWN vulnerabilities. Must be disabled on all servers.
TLS 1.0	Deprecated (RFC 8996)	Vulnerable to BEAST and POODLE attacks. Disabled in all modern browsers and required to be disabled for PCI DSS compliance since 2018.
TLS 1.1	Deprecated (RFC 8996)	Similar issues; remove alongside TLS 1.0.
TLS 1.2	Widely deployed acceptable	Secure with strong cypher suites. Remove RC4, 3DES, and export cypher suites. Used correctly, it is still acceptable.
TLS 1.3	Current standard preferred	Removed all legacy cypher suites; faster handshake (1-RTT vs 2-RTT); perfect forward secrecy mandatory; no RSA key exchange.

Compliance Note:
EXAM TIP: TLS 1.3 is mandatory for new deployments. PCI DSS 4.0 requires TLS 1.2 minimum (TLS 1.3 strongly preferred) by 2025. Healthcare (HIPAA) and government (FedRAMP) also mandate TLS 1.2+. Always configure servers to explicitly disable TLS 1.0 and 1.1.

3.4.3 VPNs — Virtual Private Networks

A VPN creates a secure, encrypted tunnel between two endpoints across an untrusted network (usually the internet). All traffic flowing through the tunnel is encrypted, preventing eavesdroppers from reading or modifying it.

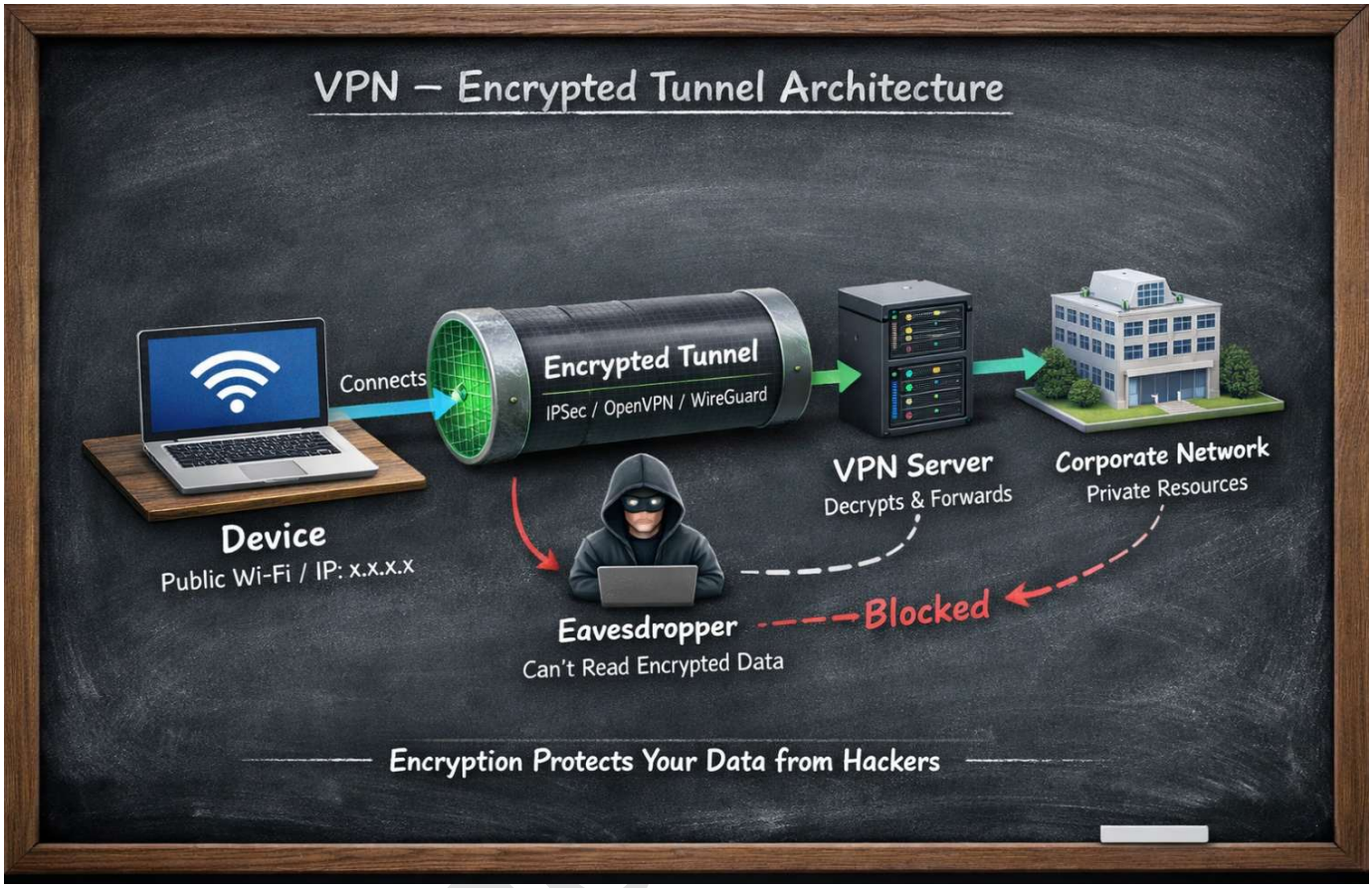

Figure: 3.4 — VPN Encrypted Tunnel: Device → Encrypted Tunnel → VPN Server → Corporate Network

VPN Types and Use Cases

VPN Type	Architecture	Best Use Case
Remote Access VPN	Individual user device → VPN server → corporate network	Employees working from home or connecting to public WiFi to access company resources.
Site-to-Site VPN	Office network → IPsec tunnel → cloud VPC or branch office	Connecting on-premises data centres to cloud VPCs; connecting branch offices.
SSL/TLS VPN	Browser-based or thin client; uses HTTPS port 443	Environments where IPsec is blocked by firewalls; clientless access to web apps.
Split-Tunnel VPN	Only corporate traffic goes through VPN; internet traffic goes direct	Reduces VPN server load; improves internet performance for remote workers.
Full-Tunnel VPN	All user traffic routed through VPN	High security environments; ensures all traffic is inspected and logged.

VPN Protocols Comparison

Protocol	Security	Performance	Notes
OpenVPN	Strong (AES-256, TLS)	Good	Open source; very configurable; uses UDP 1194 or TCP 443; widely supported.
IKEv2/IPsec	Strong	Excellent	Fast reconnection (MOBIKE); ideal for mobile. Standard for enterprise.
WireGuard	Excellent (ChaCha20)	Best	Newest; smallest codebase (4,000 lines vs 70,000); extremely fast; built into Linux kernel.
L2TP/IPsec	Moderate	Moderate	Older; double encapsulation overhead; being phased out.
PPTP	Weak (broken)	Fast	Do NOT use — MS-CHAPv2 can be cracked. Obsolete.

Case Study 3.4 — Ubiquiti 2021: Credential Theft via Misconfigured Cloud

Background: In January 2021, Ubiquiti Networks disclosed a data breach affecting customer accounts. An attacker had obtained AWS credentials from an employee's LastPass account.
Attack: Using the stolen AWS credentials, the attacker accessed Ubiquiti's AWS infrastructure, rotated legitimate credentials, and accessed customer data. The attacker demanded a $2 million ransom not to publish the data.
Connection to VPN/Secure Communications: The attacker accessed production systems directly using stolen cloud credentials — there was no VPN or bastion host requiring an additional authentication step to reach the cloud environment. A VPN with MFA between administrators and cloud management planes would have been an additional barrier.
Key Lessons: Use hardware security keys (FIDO2/YubiKey) for privileged cloud console access. Never store cloud credentials in password managers without MFA. Use AWS IAM Identity Center (SSO) instead of long-lived IAM access keys. Require VPN + MFA for access to cloud management APIs from untrusted networks.
Better Architecture: Admin workstation → VPN (MFA required) → Bastion host (in private subnet) → Cloud management plane. AWS credentials stored in Secrets Manager, not password managers.

3.5 Denial-of-Service and DDoS Attack Prevention in Cloud

A Denial-of-Service (DoS) attack aims to make a service unavailable to legitimate users by overwhelming it with traffic or requests. A Distributed DoS (DDoS) attack amplifies this by coordinating thousands or millions of compromised machines (a botnet) to attack simultaneously. DDoS targets the availability pillar of the CIA Triad.

3.5.1 Attack Categories and Mechanisms

Attack Type	Mechanism	Real-World Example
Volumetric	Overwhelm bandwidth — UDP floods, ICMP floods, DNS amplification, Memcached amplification.	NTP amplification attacks generating 400 Gbps+ against Cloudflare (2014); GitHub Memcached attack (2018, 1.35 Tbps).
Protocol / State Exhaustion	Exhaust server state tables — SYN floods, Ping of Death, fragmented packets.	SYN flood fills server's half-open connection table; legitimate connections refused. Mirai botnet 2016.
Application Layer (L7)	Expensive resource requests — HTTP GET/POST floods, Slowloris, slow reads.	Low-and-slow attacks mimicking legitimate traffic; target login or search endpoints.
Amplification	Attacker sends small packet to open server; server sends large response to the spoofed victim IP.	DNS amplification (28-54x), NTP (556x), Memcached (51,000x), CLDAP (70x).
SSL Exhaustion	Initiate many TLS handshakes without completing them — consumes server CPU for crypto.	Targets HTTPS load balancers; SSL renegotiation attacks.

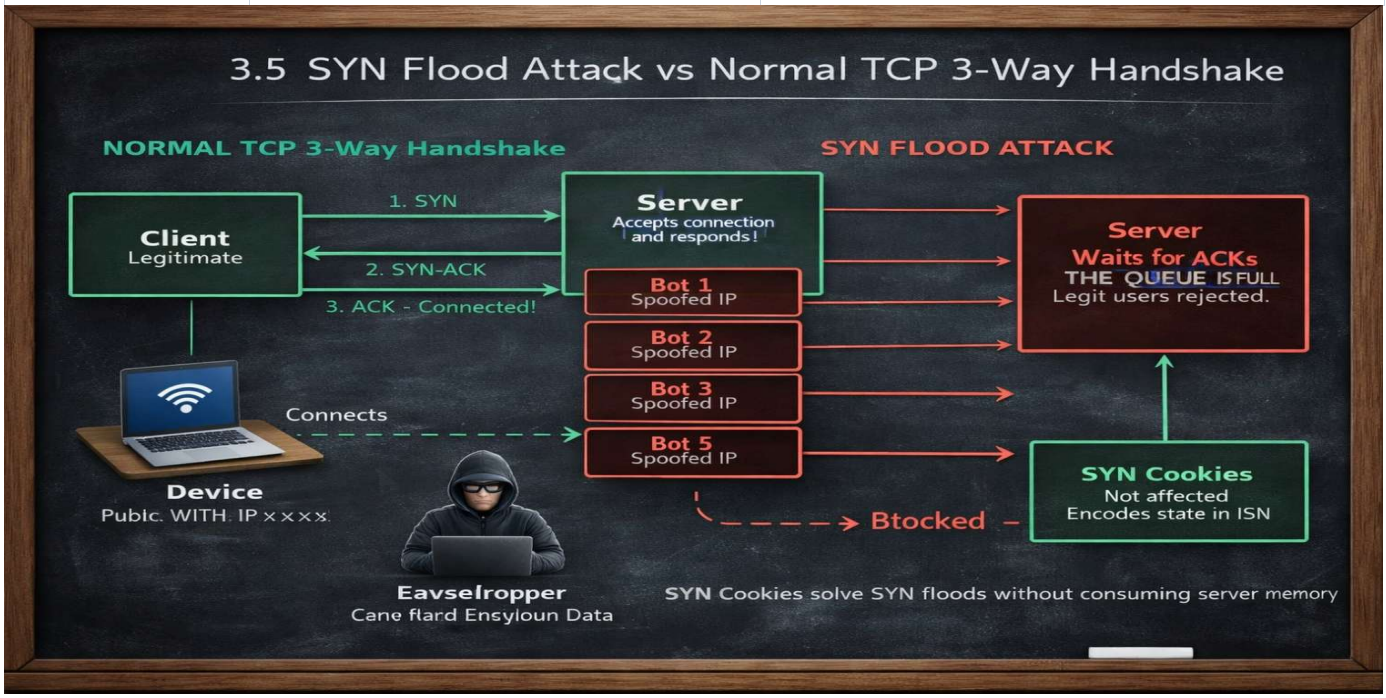

Figure 3.5 — SYN Flood Attack vs Normal TCP 3-Way Handshake, and SYN Cookie Defence

3.5.2 Real-World Case Studies

Case Study 3.5A — GitHub 2018: 1.35 Tbps Memcached DDoS Attack

Date: 28 February 2018 at 17:21 UTC.

Attack Vector: Memcached amplification — attackers found ~50,000 Memcached servers on the internet with UDP port 11211 open (no authentication). They sent 200-byte spoofed UDP requests with GitHub's IP as the source. Each Memcached server responded with up to 100 KB of data directed at GitHub.

Scale: Peak traffic: 1.35 Terabits per second (Tbps) and 126.9 million packets per second. Amplification factor: ~51,000x — the largest DDoS in recorded history at the time.

Response: At 17:21 UTC, GitHub's monitoring systems detected an anomalous traffic spike. At 17:26 UTC, GitHub routed traffic to Akamai Prolexic's scrubbing infrastructure via BGP prefix announcement. Akamai absorbed and filtered the attack traffic. At 17:30 UTC, legitimate traffic was restored. Total downtime: approximately 10 minutes.

Memcached Mitigation: GitHub had not exposed Memcached servers themselves. The attack exploited third-party Memcached servers. The global response: ISPs and cloud providers began filtering UDP 11211 at their network edges. Memcached operators were alerted to disable UDP and add firewall rules.

Lesson: Even well-secured organisations can be victims of amplification attacks using other people's misconfigured infrastructure. Defence requires working with upstream ISPs and scrubbing services, not just configuring your own servers.

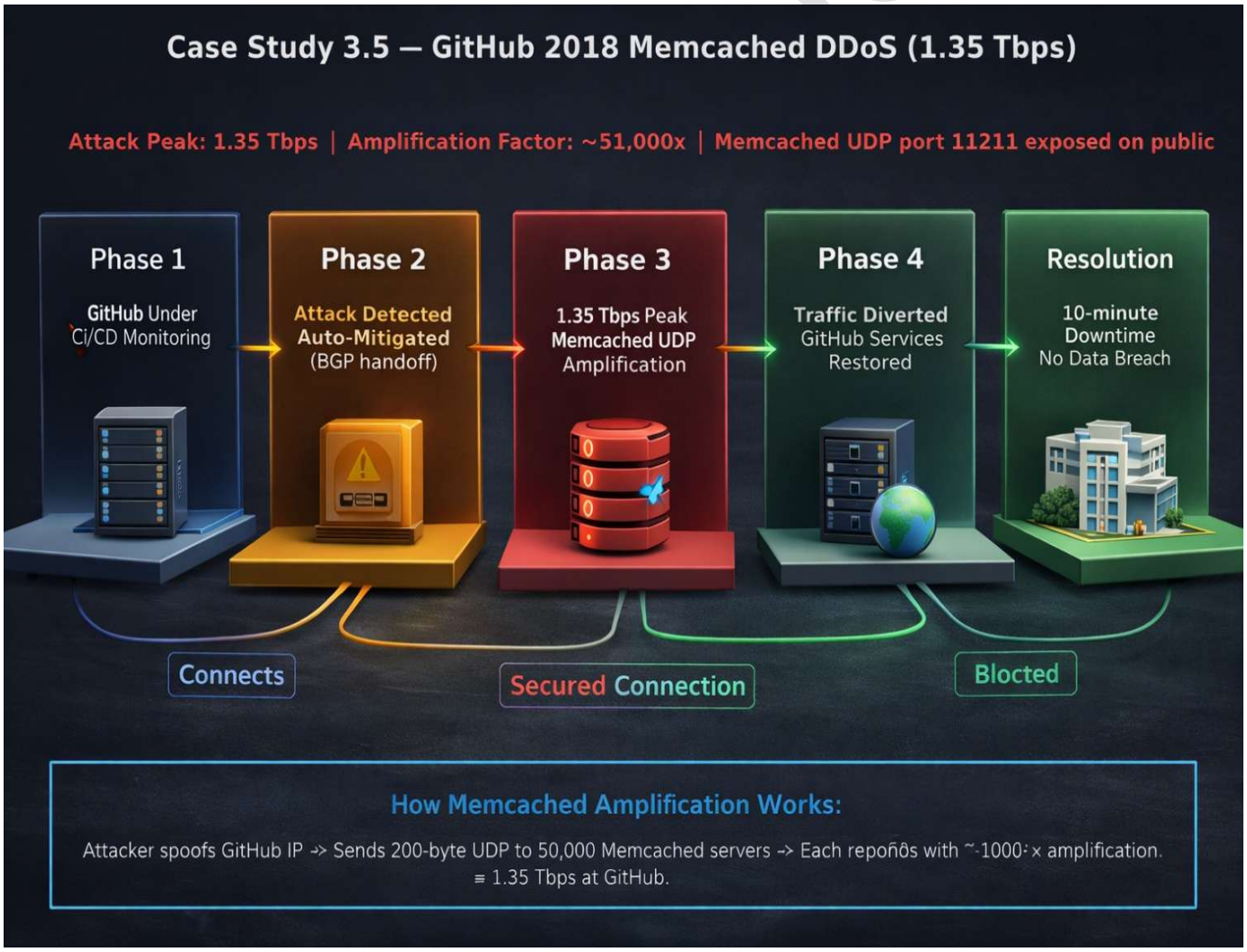

Figure: Case Study 3.5A — GitHub 1.35 Tbps Memcached DDoS: Attack Timeline and Mitigation

Case Study 3.5B — Mirai Botnet 2016: IoT DDoS Attacks

Background: Mirai was malware that infected IoT devices (CCTV cameras, DVRs, home routers) using default manufacturer credentials. It built a botnet of over 600,000 devices.
Attacks: September 2016: Brian Krebs' security blog hit with 620 Gbps. October 2016: Dyn DNS infrastructure attacked, taking down Twitter, Reddit, Netflix, Spotify, GitHub, and PayPal in the US East Coast for most of the day.
Why DNS Was Targeted: Dyn provided DNS resolution for many major websites. By overwhelming Dyn's DNS servers, users could not resolve domain names for those websites, effectively taking them offline — without attacking the websites directly.
Why IoT Devices? IoT devices use simple embedded OS, often shipped with default credentials (admin/admin, admin/password) and no automatic update mechanism. Mirai scanned the internet for telnet-accessible devices and tried a list of 61 known default credentials.
Lessons: Change default credentials immediately. Deploy IoT devices on isolated VLANs (network segmentation). Use anycast DNS with multiple providers (Dyn single-provider dependency was a critical architectural flaw). Cloud providers must build DDoS scrubbing into their DNS infrastructure.

3.5.3 Multi-Layer DDoS Defence Architecture

Figure: 3.5 — Multi-Layer Cloud DDoS Defence: CDN → DDoS Service → WAF+Rate Limit → Auto-Scale → Origin

Defence Layer	Mechanism	Cloud Services
Edge / CDN Layer	Distributed Points of Presence (PoPs) absorb volumetric attacks close to their source before traffic reaches origin. Anycast routing spreads load.	AWS CloudFront, Azure CDN, Cloudflare CDN, Akamai
Cloud DDoS Service	Always-on or on-demand scrubbing. Detects attacks using ML; reroutes via BGP or tunnels to scrubbing centres; blocks protocol attacks.	AWS Shield Standard (free), AWS Shield Advanced, Azure DDoS Protection, Google Cloud Armor
Web Application Firewall (WAF)	Inspects HTTP/S at L7. Blocks OWASP Top 10, rate limits per IP/session, blocks known bad bots, blocks geographic regions.	AWS WAF, Azure WAF, Cloudflare WAF, F5 Advanced WAF
Rate Limiting	Restricts requests per IP/user/session per time window. Adaptive rate limiting adjusts based on traffic patterns.	AWS API Gateway throttling, ALB target group limits, Nginx rate_limit
Auto-Scaling	Automatically adds compute capacity to absorb increased traffic. Combined with load balancers to distribute across instances.	AWS Auto Scaling Groups, Azure VMSS, GCP Managed Instance Groups
Anycast Routing	Routes traffic to nearest available infrastructure automatically; naturally distributes DDoS traffic across the global network.	AWS Global Accelerator, Cloudflare Anycast, Azure Front Door

3.5.4 Incident Response for DDoS Attacks

DDoS Response Playbook

Phase 1 — Detect: Monitor traffic volume (Gbps, Mpps), latency, error rates, and availability metrics continuously. Set alerting thresholds below saturation point.

Phase 2 — Classify: Identify attack type (volumetric vs protocol vs L7). Check source IP distribution, packet signatures, and request patterns.

Phase 3 — Contain: Activate upstream DDoS scrubbing (AWS Shield, Cloudflare). Implement emergency firewall rules to block identified attack patterns.

Phase 4 — Absorb: Scale out auto-scaling groups. Activate CDN caching to reduce origin load. Switch to degraded mode (serve cached pages, disable non-critical features).

Phase 5 — Recover: Gradually restore services as the attack subsides. Verify normal traffic patterns before removing emergency rules.

Phase 6 — Review: Document timeline, attack characteristics, detection lag, and effectiveness of mitigations. Update runbooks and improve monitoring thresholds.

Example — Rate Limiting Rule (AWS WAF):

Scenario: Login endpoint /api/auth/login is being flooded with 50,000 requests per minute from distributed IPs. A single valid login never exceeds 5 attempts per minute. Rule: Rate limit any IP making more than 100 requests per 5-minute window to /api/auth/login. Action: BLOCK for 5 minutes, then re-evaluate.

Additional: CAPTCHA challenge for IPs making 50-100 requests per 5 minutes (suspicious but not yet malicious threshold). Alerting: SNS notification if more than 10 IPs are blocked within 60 seconds (signals coordinated attack).

3.5.5 Cloud-Specific DDoS Challenges

Challenge	Detail and Mitigation
Cost Amplification	Auto-scaling absorbs attacks, but costs spike dramatically. Mitigate: Set auto-scaling maximum limits, use AWS Shield Advanced cost protection, and set billing alerts.
API Gateway Overload	Serverless architectures can be overwhelmed at the API layer even when the backend is fine. Mitigate: API throttling, usage plans, WAF rate limiting in front of API Gateway.
Shared Infrastructure Impact	DDoS on one tenant may degrade performance for neighbours on shared infrastructure. Mitigate: Choose dedicated infrastructure for critical services; use cloud providers with strong tenant isolation guarantees.
IPv6 Attack Surface	Many DDoS protections are IPv4-centric; IPv6 address space is vast and harder to block by prefix. Mitigate: Apply equivalent rules to IPv6; some CDN providers handle this transparently.
Encrypted Attack Traffic	L7 attacks over HTTPS cannot be inspected without TLS termination. Mitigate: Terminate TLS at the CDN/WAF layer before applying inspection rules.
IoT Botnet Growth	IoT devices add millions of attack-capable endpoints annually. Mitigate: Upstream volumetric scrubbing is the only effective defence; you cannot block millions of IPs individually.

Key Principles:
SUMMARY — DDoS Defence Principles:
(1) You cannot defend alone — upstream scrubbing partnerships are essential.
(2) Layers are complementary — CDN absorbs volume; WAF blocks L7; rate limiting prevents resource exhaustion; auto-scaling absorbs what gets through.
(3) Capacity beats filtering for volumetric attacks — make yourself bigger than the attack.
(4) Prepare before the attack — DDoS response playbooks, pre-configured protections, and contact numbers for upstream providers must be ready before the attack starts.

Chandan